

GoTestWAF

API / Application Security Testing Results

Overall grade:

A-
90.9 / 100

Project name : Kong Armor

URL : <https://vittima.xyz>

Testing Date : 15 July 2024

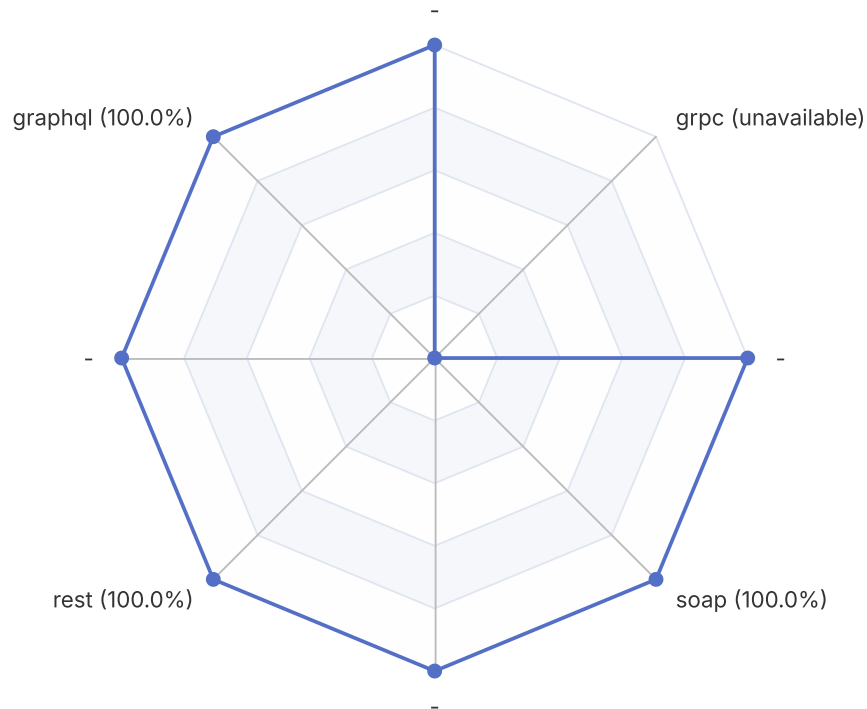
GoTestWAF version : v0.4.19

Test cases fingerprint : 90f1b5a80ca74c1d24fa9bcf2cf75a5

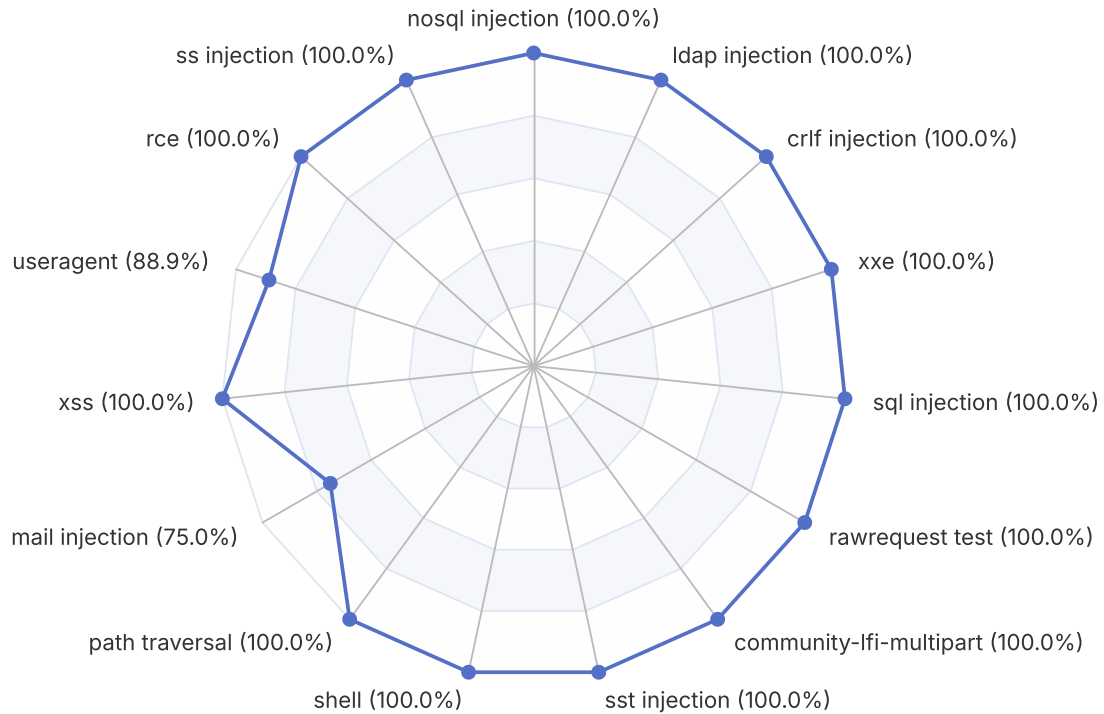
Used arguments : --url=<https://vittima.xyz> --wafName="Kong Armor" --noEmailReport --includePayloads --skip WAFIdentification

Type	True-positive tests blocked		True-negative tests passed		Grade	
API Security	A+	100.0%	N/A	0.0%	A+	100.0%
Application Security	A+	98.9%	D	64.5%	B-	81.7%

API Security



Application Security



Benchmarks against other solutions

Type	API Security		Application Security		Overall score	
ModSecurity PARANOIA=1	F	27.3%	D	66.8%	F	47.0%
ModSecurity PARANOIA=2	F	40.9%	F	58.2%	F	49.6%
ModSecurity PARANOIA=3	B	86.4%	F	50.4%	D+	68.4%
ModSecurity PARANOIA=4	A+	100.0%	F	36.0%	D+	68.0%
Wallarm	A+	100.0%	A+	97.7%	A+	98.9%
Your project	A+	100.0%	B-	81.7%	A-	90.9%

Details

Summary

Total requests sent: 797
Number of blocked requests: 683
Number of passed requests: 98
Number of unresolved requests: 16
Number of failed requests: 0

True-positive tests

Test set	Test case	Percentage	Blocked	Bypassed	Unresolved	Sent	Failed
community	community-128kb-rce	0.00%	0	0	1	1	0
community	community-128kb-sqli	0.00%	0	0	1	1	0
community	community-128kb-xss	0.00%	0	0	1	1	0
community	community-16kb-rce	0.00%	0	0	1	1	0
community	community-16kb-sqli	0.00%	0	0	0	0	0
community	community-16kb-xss	0.00%	0	0	0	0	0
community	community-32kb-rce	0.00%	0	0	1	1	0
community	community-32kb-sqli	0.00%	0	0	0	0	0
community	community-32kb-xss	0.00%	0	0	0	0	0
community	community-64kb-rce	0.00%	0	0	1	1	0
community	community-64kb-sqli	0.00%	0	0	1	1	0
community	community-64kb-xss	0.00%	0	0	1	1	0
community	community-8kb-rce	0.00%	0	0	1	1	0
community	community-8kb-sqli	0.00%	0	0	0	0	0
community	community-8kb-xss	0.00%	0	0	0	0	0
community	community-lfi	0.00%	0	0	0	0	0
community	community-lfi-multipart	100.00%	2	0	0	2	0
community	community-rce	100.00%	4	0	0	4	0
community	community-rce-rawrequests	100.00%	3	0	0	3	0
community	community-sqli	100.00%	12	0	0	12	0
community	community-user-agent	88.89%	8	1	0	9	0
community	community-xss	100.00%	104	0	0	104	0
community	community-xxe	100.00%	2	0	0	2	0
Summary for community		98.41%	135	1	9	145	0
owasp	crlf	100.00%	7	0	0	7	0
owasp	ldap-injection	100.00%	24	0	0	24	0
owasp	mail-injection	75.00%	18	6	0	24	0
owasp	nosql-injection	100.00%	50	0	0	50	0
owasp	path-traversal	100.00%	20	0	0	20	0

owasp	rce	100.00%	18	0	0	18	0
owasp	rce-urlparam	0.00%	0	0	0	0	0
owasp	shell-injection	100.00%	32	0	0	32	0
owasp	sql-injection	100.00%	36	0	0	36	0
owasp	ss-include	100.00%	24	0	0	24	0
owasp	sst-injection	100.00%	24	0	0	24	0
owasp	xml-injection	100.00%	6	0	0	6	0
owasp	xss-scripting	100.00%	223	0	1	224	0
Summary for owasp		97.92%	482	6	1	489	0
owasp-api	graphql	100.00%	3	0	3	6	0
owasp-api	graphql-post	100.00%	1	0	1	2	0
owasp-api	grpc	0.00%	0	0	0	0	0
owasp-api	non-crud	0.00%	0	0	2	2	0
owasp-api	rest	100.00%	7	0	0	7	0
owasp-api	soap	100.00%	5	0	0	5	0
Summary for owasp-api		100.00%	16	0	6	22	0
Summary for true-positive tests		98.91%	633	7	16	656	0

True-negative tests

Test set	Test case	Percentage	Blocked	Bypassed	Unresolved	Sent	Failed
false-pos	texts	64.54%	50	91	0	141	0

True Negative Tests

91 true-negative requests identified as bypassed (test passed, good behavior)

50 true-negative requests identified as blocked (test failed, bad behavior)

Payload	Test case	Encoder	Placeholder	Status
)I would like to request information about the address: (#)saddr for the next minute.	texts	URL	URLParam	403
,I would like to request information about the shadow EXFFJT.	texts	URL	URLParam	403
1) a-b=c	texts	URL	URLParam	403
=Can I please adjust_campaign:sign?	texts	URL	URLParam	403
D'or 1st perfume	texts	URL	URLParam	403
DEAR FINN,--I think it would do; copy should reach us second post	texts	URL	URLParam	403
DELETE 75oBC\$	texts	URL	HTMLForm, HTMLMultipartForm, URLParam	403
I setted the COOKIE value to : expandGeoJsonFeatures=true;	texts	URL	URLParam	403
I would like to be notified when the ASIN: B07JJS7WY7 is back in stock.	texts	URL	URLParam	403
I would like to keep-alive my connection and have the full_text of the article, please.	texts	URL	URLParam	403
I would like to request a random number between 1 and 10, please.	texts	URL	URLParam	403

I would like to request information about the idv_msdb database.	texts	URL	URLParam	403
I would like to request the bin with app_id: (]	texts	URL	URLParam	403
I would like to request the local version of the website in French, so I will include the parameter "hl=fr"	texts	URL	URLParam	403
I would like to search for the string "%t" please.	texts	URL	URLParam	403
I would like to see a list of drivers sorted in reverse order.	texts	URL	URLParam	403
If the subject parameter is greater than 0, then return a list of all articles with that subject.	texts	URL	URLParam	403
JavaScript: Basics of JavaScript Language	texts	URL	HTMLMultipartForm, HTMLForm, URLParam	403
MKCALENDAR cursor:I would like to create a new calendar called "cursor" please.	texts	URL	URLParam	403
The Senora found herself a heroine; more than that, she became aware	texts	URL	URLParam	403
The parameter 5 is& .	texts	URL	URLParam	403
The standard for the <\$ tag is to enclose text or code that should be interpreted as a dollar amount.	texts	URL	URLParam	403
[Host: type: {[	texts	URL	URLParam	403
_I would like to see the runtime for the payload, please.	texts	URL	URLParam	403
_SELECT all the rows of fromDate = @-	texts	URL	URLParam	403
and &IN=color&=	texts	URL	URLParam	403
and =IS=C5HF95_ =	texts	URL	URLParam	403
and >I would like to see all of the items that are type <enter type here>.	texts	URL	URLParam	403
bash away in the gym	texts	URL	URLParam	403
curl and divergence	texts	URL	URLParam	403
echo in the mirror	texts	URL	URLParam	403
exec noun	texts	URL	URLParam	403
java lang courses	texts	URL	URLParam	403
1https://www.instagram.com/p/B_uHgI7lY0Z/?igshid=1m7xkk7a9v6z4&utm_source=ig_web_copy_linkCan I please get the id for the user that I am trying to follow?	texts	URL	URLParam	403
ls 300 lexus	texts	URL	URLParam, HTMLForm, HTMLMultipartForm	403
nc 8000 controller	texts	URL	URLParam	403
time he came.	texts	URL	URLParam	403
union was a great select	texts	URL	URLParam, HTMLForm, HTMLMultipartForm	403
zsh is the best!	texts	URL	URLParam, HTMLMultipartForm, HTMLForm	403
}I would like to request the /cc serviceCode with the parameter: serviceCode {}	texts	URL	URLParam	403

Bypasses in Details

7 malicious requests have bypassed the security solution

Payload	Test case	Encoder	Placeholder	Status
QUIT	mail-injection	Base64Flat, URL	URLParam, HTMLForm, HTMLMultipartForm	200
mercuryboard_user_agent_sql_injection.nasl '	community-user-agent	Plain	UserAgent	200

Unresolved requests in Details

16 requests identified as blocked and passed or as not-blocked and not-passed

Payload	Test case	Encoder	Placeholder	Status
1e1 union select users from password	non-crud	Plain	NonCRUDRequestBod	405
<<script/src=http://xss.com/xss.js></script	xss-scripting	URL	URLPath	400
<script>aaa</script>	non-crud	Plain	NonCRUDRequestBod	405
AA AAA AAAAAAAAAAAAAA ... truncated 130799 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAA;<script>aalert(1);</script>	community-128kb-xss	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 130819 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAAAAAA;\$\$(printf 'hsab/nib/ e- 5321 1.0.0.721 cn' rev)	community-128kb-rce	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 130827 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAA' UNION SELECT username ':' password FROM users	community-128kb-sqli	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 16131 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAAAAAA;\$\$(printf 'hsab/nib/ e- 5421 1.0.0.721 cn' rev)	community-16kb-rce	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 32515 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAAAAAA;\$\$(printf 'hsab/nib/ e- 5321 1.0.0.721 cn' rev)	community-32kb-rce	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 65263 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA;<script>aalert(1);</script>	community-64kb-xss	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 65283 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAAAAAA;\$\$(printf 'hsab/nib/ e- 5321 1.0.0.721 cn' rev)	community-64kb-rce	URL	HTMLForm	400
AAA AAA AAAAAAAAAAAAAA ... truncated 65291 symbols ... AAAAAAAAAAAAAAAAAAAAA AAA AAAAA' UNION SELECT username ':' password FROM users	community-64kb-sqli	URL	HTMLForm	400
AAA AAA				

AAAAAAAAAAAAA ... truncated 7939 symbols ... AAAAAAAAAAAAAAAAAAAAAA AAA AAAAAAAAAA;\$ (printf 'hsab/nib/ e- 8321 1.0.0.721 cn' rev)	community-8kb-rce	URL	HTMLForm	400
{"query": "query IntrospectionQuery {__schema {queryType { name }mut ationType { name }subscriptionType { name }types {...FullType}direct ives {namedescriptionlocationsargs {...InputValue}}}}fragment FullTy pe on __Type {kindnamedescriptionfields(includeDeprecated: true) {na medescriptionargs {...InputValue}type {...TypeRef}isDeprecateddeprec ationReason}inputFields {...InputValue}interfaces {...TypeRef}enumVa lues(includeDeprecated: true) {namedescriptionisDeprecateddeprecatio nReason}possibleTypes {...TypeRef}}fragment InputValue on __InputVal ue {namedescriptiontype { ...TypeRef }defaultValue}fragment TypeRef on __Type {kindnameofType {kindnameofType {kindnameofType {kindnameo fType {kindnameofType {kindnameofType {kindnameofType {kindnam e}}}}}}}}"} }	graphql-post	Plain	JSONBody	400
{__schema{queryType{name}mutationType{name}subscriptionType{name}typ es{...FullType}directives{name description locations args{...InputVa lue}}}}fragment FullType on __Type{kind name description fields(incl udeDeprecated:true){name description args{...InputValue}type{...Type Ref}isDeprecated deprecationReason}inputFields{...InputValue}interfa ces{...TypeRef}enumValues(includeDeprecated:true){name description is Deprecated deprecationReason}possibleTypes{...TypeRef}}fragment Inp utValue on __InputValue{name description type{...TypeRef}defaultValu e}fragment TypeRef on __Type{kind name ofType{kind name ofType{kind name ofType{kind name ofType{kind name ofType{kind name ofType{kind name ofType{kind name}}}}}}}} }	graphql	URL	HTMLMultipartForm, HTMLForm, URLParam	400